

PhishLens: AI-Powered Phishing Email Detection Platform

A Secure Full-Stack Web Application with Explainable ML Detection and Role-Based Access Control

Tandin Wangyel Â· Tashi Namgay Â· Gaki Palden Â· Melam Rabzang

Crown Institute of Higher Education | CIHE240943 Â· CIHE241207 Â· CIHE240539 Â· CIHE240648

BEST F1-SCORE

98.05%

Stacking Â· Random Forest

DETECT PHISHING

EXPLAIN RISK INDICATORS

PROTECT USERS

ENSEMBLE ML (BERT Â· DISTILBERT Â· LLAMA)

SECURE DEVSECOPS ARCHITECTURE

ABSTRACT

*PhishLens is a secure full-stack web platform that integrates AI-assisted phishing email detection, explainable risk outputs, and role-based workflows for users, researchers, and administrators. Built using Agile + DevSecOps methodology, the system combines a React/Vite frontend, Express backend API, MongoDB persistence, and a FastAPI ML service. Three transformer-based models Â· BERT, DistilBERT, and LLaMA Â· were trained on 18,000 emails and evaluated both individually and through five ensemble techniques. The best method, Stacking with Random Forest, achieved **98.44% accuracy** and **F1-score of 0.9805**. The platform provides confidence scores, suspicious indicator explanations, RBAC dashboards, dataset upload/training workflows, 2FA security, and comprehensive testing evidence.*

INTRODUCTION

- Phishing emails exploit **human psychology** using urgency, impersonation, and fake authority to steal credentials
- Attack wording evolves constantly, making rule-based filters insufficient
- AI and transformer models learn language patterns that generalise to novel attacks
- Secure design is essential: platforms storing accounts and ML predictions must enforce authentication, access control, and audit trails from the start

Many existing projects stop at model evaluation. PhishLens integrates **explainable detection**, **RBAC**, **2FA**, **dataset workflows**, and **testing evidence** into a single deployable system.

OBJECTIVES

- Design a **secure AI-assisted platform** that classifies email content and explains suspicious indicators
- Train and compare **BERT, DistilBERT, and LLaMA** models on 18,000 labelled emails
- Combine models using **5 ensemble techniques**: Hard Voting, Soft Voting, Weighted Voting, StackingÂ·LR, StackingÂ·RF
- Implement **bcrypt + JWT + RBAC + TOTP 2FA** security controls
- Provide researcher and admin **role-specific dashboards** with activity logging
- Validate with unit tests, Locust load testing, and OWASP ZAP security scanning

DATASET & METHODOLOGY

- 18,000 emails** from Kaggle dataset (18,650 total); labelled Safe / Phishing
- TF-IDF vectorisation + domain-specific features (URL count, uppercase ratio, suspicious keyword count)
- Split: **70% train / 15% validation / 15% test**

1

DATA
Download & clean 18k emails

2

FEATURES
TF-IDF + domain features

3

TRAIN
BERT / DistilBERT / LLaMA

4

ENSEMBLE
5 combination strategies

5

EVALUATE
Accuracy, F1, Precision, Recall

SECURE SYSTEM ARCHITECTURE

React / Vite

Frontend
Detector Â· Auth Â· Dashboards

Express API

JWT Â· RBAC Â· Proxy
JSON-only responses

MongoDB

Users Â· Datasets
Predictions Â· Logs

FastAPI

ML Service
Predict Â· Train Â· Ensemble

Model Files

pkl Â· vectorizers
notebooks Â· CSV

Design principle: the browser never calls the ML service directly. The Express backend validates every request, enforces RBAC, stores audit records, and returns JSON-only responses.

SECURITY CONTROLS

- bcrypt password hashing + JWT login
- TOTP-based optional 2FA (QR code setup)
- Role middleware: admin / researcher / user
- CSV-only upload + Pydantic validation
- MongoDB operator sanitisation
- Prediction history & activity logs

ROLE DASHBOARDS

- User:** submit emails, view predictions & explanations
- Researcher:** upload CSV datasets, trigger training, view model metrics & confusion matrix
- Admin:** approve/suspend accounts, assign roles, view activity logs & platform stats

HOW PHISHLENS IDENTIFIES PHISHING

Suspicious keyword analysis on 18,000 emails:

Reward / Greed		2,972
Authority		1,589
Action Demand		1,153
Time Pressure		707
Threat / Fear		177

Average urgency score:

0.58

Legitimate

0.90

Phishing

Keywords: **click** **password** **account** **login** **verify**
security **bank**

INDIVIDUAL MODEL RESULTS

Trained on 18,000 emails Â· 5 epochs each:

Model	Acc	Prec	Recall	F1
BERT	97.74%	95.86%	98.49%	97.15%
DistilBERT	97.70%	95.95%	98.30%	97.11%
LLaMA	98.07%	96.50%	98.68%	97.58%

5

EPOCHS
EACH MODEL

18k

EMAILS
TRAINED

LLaMA

BEST
INDIVIDUAL

ENSEMBLE METHOD RESULTS

Ensemble Method	Acc	F1
Hard Voting	98.04%	97.53%
Soft Voting	98.04%	97.53%
Weighted Voting	98.04%	97.53%
Stacking Â· LR	98.11%	97.62%
Stacking Â· RF	98.44%	98.05%

Best Method: **Stacking Â· Random Forest** achieved the highest F1-Score of **0.9805** with Precision 96.70% and Recall 99.43%

PERFORMANCE & TESTING

Locust Load Test (50 users):	Unit Testing (pytest):
POST /predict (Phishing): ~11ms median	22/22 tests passed (100%)
POST /predict (Safe): ~11ms median	Auth: register, login, JWT, 2FA
34,263 phishing requests: 0% failure	RBAC: admin/researcher route protection
34,126 safe requests: 0% failure	ML: predict phishing/safe, batch, risk level
GET /datasets/all: 1,200ms avg (large payload)	Security: invalid token, short password

OWASP ZAP Security Scan (alerts identified):

- CSP Header Missing
- Anti-clickjacking Header
- Sub-resource Integrity
- Content-Type Options
- No Critical Vulnerabilities

PLATFORM COMPONENTS

Frontend (React/Vite):

- Email detector with model selector
- Confidence + indicator explanation output
- Gemini-fallback plain-language reasoning
- Role-specific dashboards (user/researcher/admin)

ML Service (FastAPI):

- Single-model prediction: BERT, DistilBERT, LLaMA
- Ensemble: voting + stacking methods
- CSV dataset upload Â· preprocessing Â· training
- Fallback scoring when weights absent

2FA Workflow:

- Enable TOTP Â· Scan QR Â· Verify OTP
- Login (Password + OTP) Â· JWT Issued

SECURITY REQUIREMENTS & CONTROLS

Requirement	Implemented Control
Authentication	bcrypt hashing Â· JWT Â· account status Â· optional TOTP 2FA
Authorization	Role middleware for admin & researcher routes; protected dashboards
Input Safety	Request limits Â· CSV-only upload Â· Pydantic validation Â· MongoDB sanitisation
Data Protection	Password hashes & 2FA secrets removed from API responses
Auditability	Prediction history Â· dataset metadata Â· activity logs (100+ entries)

CONCLUSION & FUTURE WORK

- Stacking Â· RF ensemble** outperforms all individual models: Acc 98.44%, F1 0.9805
- Platform successfully integrates **explainable detection + RBAC + 2FA + logging** into a single system
- 22/22 unit tests pass; 0% failure rate under 50-user Locust load

Future Enhancements:

- Production DistilBERT/BERT weights
- SPF/DKIM/DMARC intelligence
- Docker Compose + CI/CD
- Refresh tokens
- Password reset flow
- Production monitoring stack

KEY OUTCOMES

ðŸ’”

SECURE

JWT Â· RBAC Â· TOTP 2FA Â· bcrypt Â· activity logs

ðŸ’–

INTELLIGENT

BERT Â· DistilBERT Â· LLaMA Â· 5 ensemble methods

ðŸ’¡

EXPLAINABLE

Indicators Â· risk terms Â· confidence score Â· plain-language reasoning

ðŸ’–

RESEARCH-READY

CSV upload Â· training pipeline Â· model comparison Â· metrics dashboard

âœ…

VALIDATED

22/22 unit tests Â· Locust load testing Â· OWASP ZAP scanning